# DATA PRIVACY CASE STUDY & COMPLIANCE PLAN: THE 2016 COMELEC DATA BREACH

## COURSE: DATA PRIVACY ACT OF 2012 (RA 10173)

## GROUP MEMBERS:

EGNO, ACE ARTHUR
JUANITES, MARTIN LORENZ
LOGRONIO, MICHAEL
PULAO, ROMAR

# CASE BACKGROUND

## THE INCIDENT

In March 2016, the COMELEC website was hacked by “Anonymous Philippines,” who defaced the site and accessed its backend. Shortly after, another group called “LulzSec Pilipinas” leaked the entire voter database online. The breach exposed the personal data of around 55 million voters, making it the largest government data leak in Philippine history and revealing major weaknesses in COMELEC’s security systems.

## WHAT HAPPENED

- The website was defaced and later fully accessed by hackers.
- The entire voter database was extracted and posted publicly on several websites.
- Sensitive information of 55 million Filipino voters was leaked.

## EXPOSED INFORMATION:

- Full name
- Address
- Birthdate
- Passport numbers
- Fingerprint data
- Registered precinct information

PAGE 2 →

# VIOLATIONS OF THE DATA PRIVACY ACT & AFFECTED PARTIES

## VIOLATIONS OF RA 10173 (DATA PRIVACY ACT):

- Security Principle Violation – COMELEC failed to implement adequate security measures.
- Accountability Principle Violation – No effective protection, monitoring, or breach protocol.
- Transparency Principle Violation – Insufficient communication to the public regarding risks.
- Unauthorized Processing and Access of personal information.

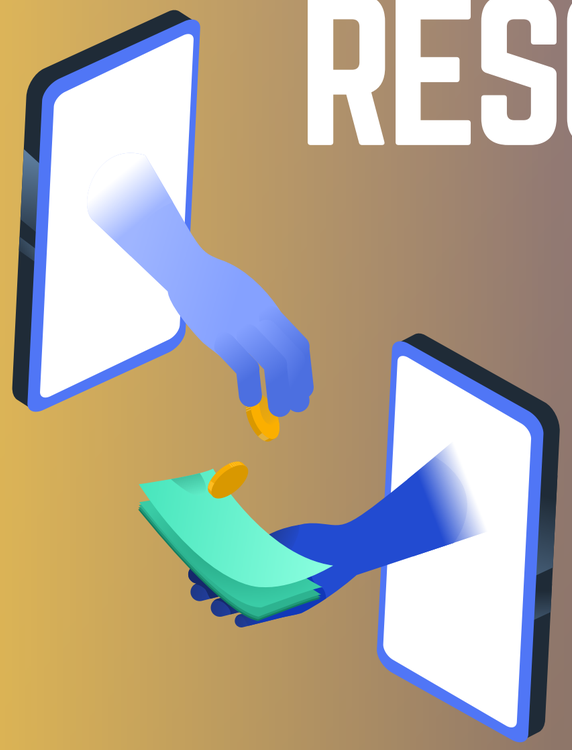
## WHO WERE AFFECTED:

- Around 55 million registered voters in the Philippines.
- Overseas Filipino Voters.
- COMELEC as an institution.

## HOW THEY WERE AFFECTED:

- Increased risk of identity theft and fraud.
- Possible misuse of personal and passport details.
- Loss of trust toward government digital systems.

PAGE 3 →



# RESOLUTION & CORRECT HANDLING

## WHAT HAPPENED AFTER THE BREACH:

- The National Privacy Commission (NPC) investigated the incident.
- COMELEC was held liable for violating the Data Privacy Act.
- NPC recommended administrative and criminal charges against the COMELEC Chair at that time.
- COMELEC was required to improve its cybersecurity measures.

## WHAT SHOULD HAVE BEEN DONE

- Implement strong encryption for voter databases.
- Conduct regular security audits and penetration testing.
- Assign a qualified Data Protection Officer (DPO).
- Establish breach notification procedures within 72 hours.
- Apply proper access control and server hardening practices.

# COMPLIANCE PLAN: PREVENTIVE MEASURES

### 1. ENCRYPTION & SECURE STORAGE

– Fully encrypt all voter data and sensitive information.

### 2. REGULAR SYSTEM AUDITS

– Annual penetration testing, vulnerability scanning, and third-party audits.

### 3. ACCESS CONTROL POLICIES

– Implement role-based access, MFA, and strict admin privileges.

### 4. INCIDENT RESPONSE PLAN

– Clear procedures for breach reporting, recovery, and communication.

### 5. DATA MINIMIZATION

– Collect only necessary data and avoid storing excessive information.

### 6. EMPLOYEE TRAINING & AWARENESS

– Ensure employees understand their responsibilities under the Data Privacy Act.

PAGE 5 →

# PRIVACY PRINCIPLES APPLIED

## 1. TRANSPARENCY

Organizations must clearly inform the public how their data is collected, processed, and protected.

## 2. DATA MINIMIZATION

Only collect personal data that is necessary for official purposes.

## 3. PROPORTIONALITY

Data processing must be fair, legitimate, and aligned with its stated purpose.

## 4. ACCOUNTABILITY

COMELEC must demonstrate compliance with RA 10173 through proper documentation, policies, and technical safeguards.

# ETHICAL & TECHNICAL SAFEGUARDS

## ETHICAL SAFEGUARDS:

- Mandatory training for COMELEC staff on data privacy and cybersecurity.
- Establish clear data handling guidelines and disciplinary actions.
- Ensure proper breach reporting and coordination with NPC.

## TECHNICAL SAFEGUARDS:

- Encryption (at rest and in transit)
- Firewall and intrusion detection systems
- Multi-factor authentication
- Regular backups in secure off-site locations
- Continuous security monitoring
- Secure server configuration and patch management

# THANK YOU

## REFERENCES

National Privacy Commission. (2016, December 28). *Privacy Commission recommends criminal prosecution of COMELEC Chair Bautista over "Comeleak" data breach*. Retrieved from https://privacy.gov.ph/privacy-commission-finds-bautista-criminally-liable-for-comeleak-data-breach/

Bueza, M.(2017, January 5). *Comelec chair 'criminally liable' for data leak*. Retrieved from https://www.rappler.com/philippines/157418-comelec-chair-bautista-criminally-liable-voters-data-leak/

SunStar. (2017, January 5). *Privacy body finds Comelec chair 'criminally liable' for data breach*. Retrieved from https://www.sunstar.com.ph/more-articles/privacy-body-finds-comelec-chair-criminally-liable-for-data-breach

Ronda, R. A. (2017, January 6). *Comeleak: Bautista faces criminal raps*. The Philippine Star. Retrieved from https://www.philstar.com/headlines/2017/01/06/1659984/comeleak-bautista-faces-criminal-raps